

Meridian Health (Track A)

-Scan results:

[CRITICAL] staff-wiki - Apache Tomcat AJP Ghostcat File Read/Inclusion (CVE-2020-1938)
[HIGH] patient-portal-web - nginx Range Filter Integer Overflow (CVE-2022-41741)
[HIGH] appt-scheduler-web - nginx Range Filter Integer Overflow (CVE-2022-41741)
[MEDIUM] lab-results-svc - OpenSSH Pre-Authentication User Enumeration (CVE-2018-15473)
[MEDIUM] ehr-db-01 - PostgreSQL Privilege Escalation via ALTER ... DEPENDS ON EXTENSION (CVE-2020-14349)

-Risk register:

[10.32] patient-portal-web nginx Range Filter Integer Overflow (CVE-2022-41741)
[9.00] ehr-db-01 PostgreSQL Privilege Escalation via ALTER ... DEPENDS ON EXTENSION (CVE-2020-14349)
[8.40] appt-scheduler-web nginx Range Filter Integer Overflow (CVE-2022-41741)
[7.20] lab-results-svc OpenSSH Pre-Authentication User Enumeration (CVE-2018-15473)
[4.00] staff-wiki Apache Tomcat AJP Ghostcat File Read/Inclusion (CVE-2020-1938)

Phase 4 — Threat Modeling Workshop

Finding (host / CVE)	STRIDE category	Threat description	Existing or missing control	Framework mapping
[CRITICAL] staff-wiki - Apache Tomcat AJP Ghostcat File Read/Inclusion (CVE-2020-1938)	I-Informat ion disclosur e	Apache Tomcat is a Java web application server. Older versions of Tomcat had an AJP connector that could be exposed to attackers. If an attacker could reach the AJP port, they could potentially: -Read arbitrary files from a	Control: Access Control / Network Segmentation Restrict access to the Tomcat AJP port (typically port 8009) so that only trusted systems can	TTP (attacker could take advantage of AJP connector that could lead to data exposure of employee PII—data theft

		web application. -Process files as JSP (Java Server Pages). -Under certain conditions, achieve remote code execution (RCE).	connect to it. If AJP is not needed, disable the connector entirely.	
[HIGH] patient-portal-web - nginx Range Filter Integer Overflow (CVE-2022-41741)	D- Denial of Service	An attacker who has local access and can cause NGINX to process a specially crafted audio/video file can trigger memory corruption in an NGINX worker process. This can cause the worker to terminate and may have additional security impacts.	Control: Patch Management / Vulnerability Management: Update NGINX to version that contains the security fix.	TTP (attacker could cause a denial of service by causing memory corruption to disrupt operations
[HIGH] appt-scheduler-web - nginx Range Filter Integer Overflow (CVE-2022-41741)	D- Denial of Service	a specially crafted audio/video file can cause memory corruption in an NGINX worker process. This can cause the worker to terminate and potentially have other security impacts.	Control: Patch Management / Vulnerability Management Control: Upgrade NGINX to a fixed version, 1.22.1 or later (stable) or 1.23.2 or later (mainline). NGINX identifies those versions as not vulnerable.	TTP (attacker could cause a denial of service by causing memory corruption to disrupt operations
[MEDIUM] lab-results-svc - OpenSSH Pre-Authentication User Enumeration (CVE-2018-15473)	I-Information disclosure	An attacker can send specially crafted SSH authentication requests and observe differences in how the server responds.	Control: upgrade OpenSSH to a version that fixes the vulnerability	TTP (attacker could get access to usernames, and potentially gain access if they get a password. Impacts confidentiality.
[MEDIUM] ehr-db-01 -	T-Tampering	An attacker could exploit the way PostgreSQL handled	Control: Upgrade PostgreSQL, and or	TTP (attacker could execute

PostgreSQL Privilege Escalation via ALTER ... DEPENDS ON EXTENSION (CVE-2020-14349)		the search_path during logical replication. By creating malicious database objects, the attacker could potentially cause arbitrary SQL commands to execute with the privileges of the replication user—which could be a highly privileged account.	Access Control - limit who can create database objects and who has replication privileges.	SQL commands, and could modify database information, or database objects.
---	--	--	--	---

Phase 5 — Executive Communication Deliverable

-A recent scan of Meridian Health network systems found some vulnerabilities, but there are 3 known security weaknesses that could disrupt services, expose PHI of patients, and put us at risk of non-compliance with HIPPA. A weakness in an internet facing application server could allow an unauthorized person to access files that should remain private, potentially exposing sensitive PHI. We recommend applying the vendor security update and restrict unnecessary server access. Timeline: within 5 business days. A weakness in the web server could allow a specially crafted file to cause the service to crash, potentially making applications or websites unavailable to employees or patients. We recommend updating the web server and disable unnecessary media-processing functionality. Timeline: within 5 business days. Unauthorized changes could be made to company data. A weakness in the database system could allow an authorized-but-malicious user to execute database commands with higher privileges, potentially changing or damaging important business information. We recommend applying the database security update and review accounts with elevated database privileges. Timeline: within 5 business days. Please approve immediate remediation of these three risks, with IT/security tracking completion and reporting any exceptions within 5 business days. If these weaknesses remain unaddressed, an attacker could potentially access sensitive information, disrupt business services, or make unauthorized changes to critical data, resulting in operational downtime, financial loss, and reputational damage.